

Care Access Navigator - Day 1

Healthcare Scenario & Initial Project Charter Baseline

HealthLine Regional Medical Center

IAM + GRC Healthcare Cybersecurity Capstone | Week 1: Planning

Organization	HealthLine Regional Medical Center (HRMC)	Environment	Simulated / Non-Production
Primary Focus	IAM + GRC	Data Rule	Synthetic Data Only

1. Day 1 Objective

Objective: Create a clear and realistic baseline for the hospital before any technical IAM or GRC implementation begins. Day 1 answers four simple questions: **What are we protecting? Who needs access? Which systems are involved? Where does simulated ePHI exist?**

Why this matters for an IAM/GRC beginner: Before creating accounts, roles, controls, or reports, an analyst first needs to understand the business environment. This is the foundation for later RBAC, joiner-mover-leaver (JML), access reviews, risk assessment, monitoring, and compliance work.

2. Healthcare Scenario

HealthLine Regional Medical Center (HRMC) is a fictional regional hospital created for this capstone. It represents a realistic healthcare organization with clinical, business, technology, security, and third-party users. The environment is intentionally small and fully simulated so it can be completed within the 12-week project.

Simple scenario: Doctors and nurses need patient-care information. Billing staff need financial information. HR staff need workforce records. IT supports systems. Security analysts review logs and suspicious activity. Vendors may receive temporary access. Each group needs different access, which creates the IAM and GRC challenge.

Core Departments

Department	Representative Users	Purpose in the Simulation
Clinical Services	Clinicians	Diagnosis, treatment, and clinical information
Nursing Services	Nurses	Patient care and clinical documentation
Revenue Cycle	Billing Specialists	Billing, claims, and patient financial processing
Human Resources	HR Administrators	Workforce records and lifecycle events
Information Technology	IT Support Analysts	User and application support
Cybersecurity	Security Analysts	Monitoring and investigation
Third-Party Services	Vendors	Temporary approved support access

3. Business Problem

HRMC needs to make sure the right person has the right access to the right system for the right reason - and only for the time it is needed. Without good access governance, employees or vendors may receive too much access, keep old access after a job change, remain active after termination, or use access in an unusual way.

- **Mover risk:** A nurse moves to Billing but keeps unnecessary nursing access.
- **Leaver risk:** A terminated employee account remains enabled.
- **Vendor risk:** A vendor account stays active after the approved end date.

- **Access risk:** A user accesses an unusually high number of synthetic patient records.

4. Day 1 Scope

Day 1 is a planning and documentation day. The goal is to define the environment, not to build it.

In Scope for Day 1	Not Implemented on Day 1
• Hospital scenario and departments	• Keycloak configuration
• Seven representative user populations	• Detailed RBAC permissions
• Four simulated applications	• JML workflow implementation
• Business problem and access risks	• SIEM / Sentinel setup
• Basic simulated ePHI boundary	• HIPAA or NIST control mapping
• Synthetic-data-only rule	• Tableau dashboard development
• Initial assumptions and Day 1 success criteria	• Incident simulation and control testing

5. Users and Stakeholders

The project starts with seven representative user groups. These are not final permission sets; they simply define who exists in the simulated hospital and what type of access each group may need.

User Group	Main Need	IAM/GRC Learning Point
Clinician	Clinical patient information	Clinical access should match care responsibilities
Nurse	Patient-care information	Least privilege for nursing duties
Billing Specialist	Billing and claims information	Billing access should not equal full clinical access
HR Administrator	Workforce information	Supports lifecycle events, normally no patient access
IT Support Analyst	Technical support access	Elevated access should be limited and justified
Security Analyst	Logs, alerts, evidence	Investigates suspicious access
Vendor	Temporary support access	Access should be approved, restricted, and time-limited

Key stakeholders: Department Managers approve business needs; the IAM Analyst manages identity/access; the Security Analyst investigates suspicious activity; the GRC Analyst tracks risks, controls, evidence, and remediation; HR provides workforce lifecycle information.

6. Application Inventory

Application	What It Represents	Example Synthetic Data	Primary Users
HealthLine EHR	Electronic health record simulation	Patient ID, diagnosis, clinical note, encounter	Clinicians, Nurses
MyHealthLine Patient Portal	Patient-facing portal simulation	Appointments, messages, basic health information	Limited clinical users / simulation
HealthLine Revenue Cycle	Billing and claims simulation	Account, claim, charge, insurance-related data	Billing Specialists
HealthLine Workforce Management	HR/workforce simulation	Employee ID, department, manager, employment status	HR Administrators

7. Simulated ePHI Boundary

What is simulated ePHI? It is fictional electronic patient-related information created only for the lab so the project can practice healthcare access control and security scenarios. It is not real patient data.

What does the boundary mean? Think of the boundary as a security line around the systems, logs, or evidence that contain patient-level information. Items inside the line need stronger access control, monitoring, and careful handling. Items outside the line may still be important, but they do not normally contain patient-level information.

Area	Boundary	Why
HealthLine EHR	Inside	Contains synthetic clinical patient records
MyHealthLine Patient Portal	Inside	Contains synthetic patient-facing information
HealthLine Revenue Cycle	Inside	Contains patient-linked billing/claims information
Patient-level access logs / incident evidence	Inside when patient detail is visible	May show who accessed a patient-related resource
HealthLine Workforce Management	Usually outside	Contains workforce rather than patient data
Project charter / generic diagrams	Outside	Describe the project without patient-level data
Generic RBAC/control documents	Outside when generic	Describe roles and controls without patient details
Aggregate dashboard metrics	Outside when de-identified	Shows totals/trends without patient identifiers

Simple access example: A synthetic clinician signs in, receives the Clinician role, opens a fictional patient record in HealthLine EHR, and an access event is recorded. If the activity looks unusual, the Security Analyst reviews the synthetic log. The IAM/GRC team can then decide whether access was appropriate, which control applies, and what evidence should be saved.

Mandatory rule: No real patient information, real ePHI, or production healthcare data will be used anywhere in the project.

8. Day 1 Assumptions

- HRMC is completely fictional and exists only for the capstone.
- All workforce identities, patients, events, and records are synthetic.
- Keycloak will be the primary IAM lab later in the project; no configuration is required today.
- The four healthcare applications may be mock applications, simple interfaces, or sample datasets.
- The project is designed to demonstrate IAM/GRC analyst concepts, not a full production hospital deployment.
- Detailed RBAC, JML, monitoring, risk/control mapping, and reporting will be developed in later project stages.

9. Beginner IAM / GRC Analyst View

IAM Analyst Questions	GRC Analyst Questions
• Who is the user? • What role should they have? • What access is needed? • Who approves it? • When should it change or be removed?	• What risk exists? • What control reduces the risk? • Who owns the control? • What evidence proves it worked? • What needs remediation?

10. Day 1 Deliverables & Success Criteria

Day 1 is complete when the hospital environment is understandable enough to support later IAM and GRC design. The goal is quality of the baseline, not technical implementation.

Deliverable	What to Complete	Output	Done When
Hospital Scenario	Define HRMC, departments, and non-production purpose	Short profile	A reader can explain what HRMC represents
Users & Stakeholders	Identify the seven user groups and main governance stakeholders	Simple matrix	User populations and responsibilities are clear
Application Inventory	Define the four simulated applications and purpose	Application table	Each system has a clear business purpose
Business Problem	Describe the identity/access challenge and example risks	Short section	The IAM problem is understandable to a non-technical reader
Simulated ePHI Boundary	Explain what is inside/outside, who may access it, and data rules	Boundary table + example	Sensitive-data boundary and no-real-data rule are clear
Scope & Assumptions	Record what Day 1 covers and what is deferred	Scope list	Day 1 remains realistic and achievable